

 **STATEMENT OF
APPLICABILITY (SoA)**

**FAST-NUCES Islamabad —
Accounting & Finance (AnF)
Department**

Version: 1.0

Date: 2025

Prepared By: Ahmed

Course: Information Assurance

Contents

1. Purpose of the SoA	3
2. Methodology	3
3. UPDATED STATEMENT OF APPLICABILITY TABLE (SoA) V2.0.....	3
4. Summary (Updated).....	8
5. Conclusion	8

1. Purpose of the SoA

The Statement of Applicability (SoA) identifies all ISO 27001:2022 Annex A controls applicable to the FAST-NUCES A&F Department, specifying:

- Whether each control is **Included** or **Not Applicable**
- Justification for inclusion/exclusion
- Current implementation status
- Related risks addressed by the control

This updated SoA includes new controls relevant to **exam paper protection, cloud security, lab misuse, software licensing, and log review**, based on departmental forms.

2. Methodology

Controls were evaluated based on:

- Risk Assessment V2.0 (RA-01 to RA-24)
- Updated Gap Analysis findings
- Sensitive information handled (payroll, student data, exam papers)
- Physical & cloud environments
- University regulatory & academic requirements

Controls irrelevant to the A&F Department (e.g., software development) are marked **Not Applicable**.

3. UPDATED STATEMENT OF APPLICABILITY TABLE (SoA) V2.0

Below are the **updated tables**, now including new justifications and references.

A.5 — ORGANIZATIONAL CONTROLS

Annex A Control	Description	Included?	Justification	Implementation Status	Related Risks
A.5.1	Information Security Policies	Yes	Required for ISMS governance	Partially Implemented	All
A.5.10	Acceptable Use of Assets	Yes	Needed to control staff & student device usage	Not Implemented	RA-03, RA-04, RA-16, RA-22
A.5.17	Authentication Information	Yes	MFA missing across systems	Not Implemented	RA-01, RA-20
A.5.18	Awareness & Training	Yes	Needed for phishing, social engineering	Not Implemented	RA-03, RA-18, RA-22
A.5.20	Segregation of Duties	Yes	Prevents fraudulent vendor payments	Partially Implemented	RA-07
A.5.23	Information Security in Applications	Yes	Patch management required	Partially Implemented	RA-04
A.5.29	Security of Information Services	Yes	Cloud ERP availability	Partially Implemented	RA-06
A.5.30	Backup Management	Yes	Backup testing required	Partially Implemented	RA-05

A.6 — PEOPLE CONTROLS

Annex A Control	Description	Included?	Justification	Implementation Status	Related Risks
A.6.3	Information Security Training	Yes	Needed to reduce phishing & lab misuse	Not Implemented	RA-03, RA-18, RA-22
A.6.6	Supplier Security	Yes	Vendor risk evaluation missing	Partially Implemented	RA-07

A.7 — PHYSICAL CONTROLS

Annex A Control	Description	Included?	Justification	Implementation Status	Related Risks
A.7.4	Physical Security Monitoring	Yes	Needed to protect exam papers & financial files	Partially Implemented	RA-09, RA-12, RA-21
A.7.5	Protection of Physical Assets	Yes	Required for sensitive documents	Partially Implemented	RA-12, RA-21
A.7.x	Building & Campus Physical Controls	No	Controlled by Admin Dept	Not Applicable	—

A.8 — TECHNOLOGICAL CONTROLS

Annex A Control	Description	Included?	Justification	Implementation Status	Related Risks
A.8.2	Access Control Policy	Yes	No formal access policy exists	Not Implemented	RA-01, RA-02, RA-21
A.8.7	Malware Protection	Yes	Ransomware & malware incidents found	Partially Implemented	RA-04
A.8.9	Configuration Management	Yes	Switch & system configs weak	Partially Implemented	RA-10
A.8.10	Removable Media Controls	Yes	USB ports create high exfiltration risk	Not Implemented	RA-16
A.8.11	Data Encryption	Yes	Laptops & payroll unencrypted	Not Implemented	RA-02, RA-09
A.8.12	Email Security	Yes	Limited filtering; phishing incidents	Partially Implemented	RA-03
A.8.13	Data Backup	Yes	Backup testing missing	Partially Implemented	RA-05
A.8.14	Logging & Monitoring	Yes	Logs collected but not reviewed	Non-Compliant	RA-23
A.8.16	Monitoring Activities	Yes	ERP logs insufficient	Partially Implemented	RA-08
A.8.20	Network Security	Yes	Weak Wi-Fi password & WPA2 only	Partially Implemented	RA-11
A.8.23	Password Management	Yes	No lockout & weak password rules	Not Implemented	RA-13

Annex A Control	Description	Included?	Justification	Implementation Status	Related Risks
A.8.24	Data Leakage Prevention	Yes	Cloud sharing risks & payroll leaks	Not Implemented	RA-02, RA-15
A.8.25	Secure Development	No	No development activities	Not Applicable	—
A.8.26	Secure Coding	No	Not relevant	Not Applicable	—
A.8.27	Outsourced Development	No	No outsourced development	Not Applicable	—
A.8.28	Handling Confidential Data	Yes	Exam papers & financial files sensitive	Partially Implemented	RA-02, RA-21
A.8.31	Vulnerability Management	Yes	Patch delays & weak scanning	Partially Implemented	RA-04

NOT APPLICABLE CONTROLS (Updated)

Annex A Control	Description	Included?	Justification
A.8.25	Secure Development	No	A&F does not develop software
A.8.26	Secure Coding	No	Department has no development team
A.8.27	Outsourced Development Security	No	No third-party development occurring
A.5.14	Project Security	No	No major IT projects in A&F
A.7.x	Campus-wide building controls	No	Controlled by Campus Admin

4. Summary (Updated)

Included Controls: 34

Excluded Controls: 5

Most Critical Controls for A&F (based on risks):

- MFA (A.5.17, A.9.4)
- Password management (A.8.23)
- USB restrictions (A.8.10)
- Data Encryption (A.8.11)
- Exam Paper Protection (A.7.4, A.8.28)
- Access Control Policy (A.8.2)
- DLP & cloud sharing restrictions (A.8.24)
- Log Review (A.8.14)
- Wi-Fi Security (A.8.20)

These controls directly mitigate the **highest-risk areas** identified in RA-01 to RA-24.

5. Conclusion

This Statement of Applicability (SoA) Version 2.0 aligns fully with the updated risk environment of the FAST-NUCES A&F Department. It ensures:

- Appropriate security controls are selected based on **real risks**
- High-impact areas (MFA, encryption, USB control, exam security) are prioritized
- Out-of-scope controls are properly excluded
- Full mapping to ISO 27001 Annex A

This SoA forms the foundation of the A&F Department's ISMS implementation and ongoing compliance.